

ResolvX

HR Security Policy

Broad-Audience Policy - Personnel Security Lifecycle

POL-023 · v1.0 · 2026 · Internal : Restricted

Document Information

Policy ID	POL-023
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	Head of HR
Approver	CISO
Review Cycle	Annual
Next Review	Q3 2027
Frameworks	ISO 27001:2022 A6.1–A6.6, A6.8 · NIST CSF 2.0 GV.RR, PR.AT · SOC 2 CC1.4

1. Purpose

This HR Security Policy establishes the security expectations that apply to every person who joins, works at, changes roles within, or leaves ResolvX. Expectations include screening before hire, security awareness throughout employment, and access handling at every transition.

People are both ResolvX's strongest security control and its most common point of risk so most of ResolvX's technical controls exist to support decisions people make. This policy makes sure those decisions are supported by proper screening, clear expectations set at hire, ongoing training, and a clean handoff whenever someone's role or employment changes.

2. Scope

This policy applies to all ResolvX employees and, where noted, to contractors with system access.

3. Pre-Employment & Ongoing Screening

3.1 Pre-Employment Screening

Background screening is conducted before an offer is finalised, scaled to the sensitivity of the role:

Role Sensitivity	Screening Level
Roles with standing access to Critical-tier systems or Restricted-tier data (per POL-008's Business Impact Analysis and POL-004's classification)	Enhanced screening - employment history verification, criminal background check, and reference checks
All other roles	Standard screening - identity verification and criminal background check

Head of HR retains screening records and confirms screening is complete before system access is provisioned under POL-003.

3.2 Jurisdiction-Specific Limits

Screening scope in §3.1 reflects US practice as ResolvX's primary hiring jurisdiction today. Where ResolvX hires in a jurisdiction with different legal limits on background screening (several EU member states restrict criminal background checks more narrowly than the US; some US states impose their own "ban the box" timing restrictions), Head of HR and Legal confirm the applicable local limits before extending §3.1's standard screening scope to that jurisdiction. The enhanced/standard screening table is a US-market baseline, not a claim that identical screening is legally available everywhere ResolvX might hire. A fuller jurisdiction-by-jurisdiction screening framework will be developed as ResolvX's hiring footprint expands into new regions, alongside the region-specific regulatory work already planned for India.

3.3 Periodic Re-Screening for Privileged Roles

Screening at hire reflects a person's history at one point in time and it doesn't stay current on its own. Personnel holding standing Critical-tier or admin-level access (per POL-003) are re-screened at the standard applicable to their role every 3 years, not only once at hire. Head of HR tracks re-screening due dates alongside the initial screening records in §3.1.

4. Terms of Employment & Confidentiality

- Every employee and applicable contractor signs a confidentiality/non-disclosure agreement before gaining access to ResolvX or client data, administered by Legal and Head of HR.
- Employment agreements include security responsibilities as an explicit term, not an implied expectation.
- Confidentiality obligations survive termination of employment, as stated in the employment agreement itself.

5. Security Awareness Training

- New hires complete security awareness training, including the incident reporting obligation under POL-015 §4, as part of onboarding, before independent system access is granted, not as a follow-up task.
- All personnel complete refresher security awareness training annually.
- Role-specific training supplements the general programme where relevant e.g., engineers complete secure coding awareness aligned to POL-018, and personnel handling Restricted-tier data complete data handling training aligned to POL-004.
- Head of HR tracks training completion; incomplete annual training is escalated to the individual's manager and, if unresolved, to GRC Lead.

6. Role Changes

An internal role change is a trigger event, not something access naturally catches up to over time. When a role change alters what systems or data an individual should access:

- The individual's manager notifies IT Admin of the change at the time it occurs.
- Access no longer required for the new role is removed, not left in place under the assumption it might be needed again which is consistent with least-privilege under POL-003.
- Where the new role requires enhanced screening under §3 that wasn't performed at original hire, it is completed before the new access is granted.

7. Extended Leave of Absence

An employee on parental, medical, or other extended leave still has active credentials sitting unused, which is its own exposure window even though the person hasn't left ResolvX. Leave is not treated the same as termination, but it isn't ignored either:

- For leave expected to exceed 30 days, Head of HR notifies IT Admin so that standing access can be suspended (not deleted) for the duration, suspension is reversible, unlike the destructive revocation used at termination.
- Suspended access is restored promptly upon the individual's return, coordinated between Head of HR and IT Admin.
- A suspended account that has not been reactivated within 30 days of the individual's expected return date is escalated to Head of HR to confirm current employment status, rather than left indefinitely suspended without follow-up.

8. Termination & Offboarding

System access is revoked the same day employment ends, this is distinct from, and faster than, the 5-business-day window POL-011 §8 allows for updating the asset register itself. Access revocation is immediate; register bookkeeping follows within the window POL-011 already sets. This same-day standard applies equally to contractors at engagement end, not only to employees.

- For involuntary termination, access is revoked at or before the termination conversation, coordinated between Head of HR and IT Admin, not after.
- For voluntary resignation, access is revoked at the end of the individual's final working day.
- Corporate equipment is collected as part of offboarding, consistent with POL-011 §8.
- Exit interviews reinforce the confidentiality obligations in §4 that survive termination.

8.1 Dormant Account Reconciliation

Same-day revocation depends on HR actually notifying IT Admin, a safety net exists for the case that notification doesn't happen. As part of the quarterly access review already required under POL-003, IT Admin reconciles the active access list against Head of HR's current roster. Any account active for someone no longer on that roster is treated as an immediate access control failure, escalated same day rather than held for the next quarterly cycle, and logged as a Corrective Action Plan item regardless of how it was found.

9. Disciplinary Process

Where a security policy violation warrants disciplinary action, Head of HR and Legal jointly review the matter before any termination-level action, applying the proportionate response ladder already defined in POL-002 §12 (formal warning, suspension of access, termination, or legal action for wilful misconduct).

Where the violation involves suspected insider misconduct with security implications, Head of HR is engaged as part of the incident response process under POL-015 §6, not as a separate, disconnected HR track.

10. Roles & Responsibilities

10.1 Head of HR

- Owns this policy, pre-employment and periodic screening (§3), and training tracking (§5).
- Notifies IT Admin of extended leave for suspension/restoration (§7) and coordinates termination-day access revocation (§8).
- Maintains the current roster used for dormant account reconciliation (§8.1).

10.2 IT Admin

- Executes access provisioning, role-change adjustments, leave suspension/restoration, and termination-day revocation.
- Performs dormant account reconciliation as part of the quarterly access review (§8.1).

10.3 Legal

- Administers confidentiality agreements (§4), advises on jurisdiction-specific screening limits (§3.2), and jointly reviews disciplinary matters (§9).

10.4 Managers

- Notify IT Admin of role changes affecting access (§6) and support timely training completion for their reports.

11. Exceptions

Exceptions to this policy follow the tiered approval authority and process defined in POL-026 and are logged in the Policy Exception Register.

12. Acknowledgement

All personnel acknowledge receipt and understanding of this policy at onboarding and annually thereafter, alongside the acknowledgement already required under POL-002. Acknowledgement records are maintained by Head of HR.

13. Compliance and Enforcement

Failure to complete required screening, training, or timely termination-day access revocation is treated as a control deficiency and logged in the Corrective Action Plan.

14. Document Control

Policy ID	POL-023
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	Head of HR
Approver	CISO
Review Cycle	Annual
Next Review	Q3 2027
Framework References	ISO/IEC 27001:2022 A6.1, A6.2, A6.3, A6.4, A6.5, A6.6, A6.8 · NIST CSF 2.0 GV.RR, PR.AT · SOC 2 TSC CC1.4
Related Documents	POL-002 (Acceptable Use Policy), POL-003 (Access Control Policy), POL-004 (Data Classification Policy), POL-011 (Asset Management Policy), POL-015 (Incident Management Policy), POL-026 (Policy Exception Governance Policy), Policy Exception Register

ResolvX GRC Program — Internal Use Only — v1.0 — 2026

Authorisation

Role	Name	Date
CEO		
CISO		
GRC Lead		